COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.6 · Access Controls

Mestre CyberSec · **Lesson 4.6 — Access Controls** (7:49) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Modelos: ACL (por recurso, lista); MAC (obrigatório por CLASSIFICAÇÃO — militar, SELinux); DAC (discretionary — o DONO do arquivo decide, Windows FS); RBAC (por FUNÇÃO); ABAC (attributos); time-of-day restriction.

💡 Key Exam Highlights & Critical Concepts

- MAC: o sistema decide por classificação (militar/SELinux)
- DAC: o DONO decide (Windows file permission)
- RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico

🎯 Exam Tips & Typical CompTIA Scenarios

- 'permissions determined by data classification'=MAC

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.6 — Access Controls)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Access Control List (ACL)

A list associated with a resource that specifies which users or groups can access it and what operations they are allowed to perform.

⚠️ ***Exam Trap:*** *Questões que mencionam permissões em arquivos, pastas ou recursos geralmente indicam ACL; ela pode implementar DAC (dono define) ou MAC (sistema define).*

• Mandatory Access Control (MAC)

An access control model where the system enforces access decisions based on security labels/classifications and subject clearances, not the resource owner.

⚠️ ***Exam Trap:*** *'Permissões determinadas por classificação de dados' = MAC. Exemplos: ambiente militar, SELinux. O dono do arquivo não define permissões.*

• Discretionary Access Control (DAC)

An access control model where the owner of a resource decides who can access it and what permissions they have.

⚠️ ***Exam Trap:*** *Windows NTFS permissions são o exemplo clássico. Se o dono do arquivo concede acesso, é DAC; não confunda com MAC.*

• Role-Based Access Control (RBAC)

An access control model that grants permissions based on a user's role or job function rather than their individual identity.

⚠️ ***Exam Trap:*** *Padrão enterprise: permissões por função/cargo. Se a questão menciona 'role' ou 'job function', escolha RBAC.*

• Attribute-Based Access Control (ABAC)

An access control model that evaluates multiple attributes (user, resource, environment, action) to make dynamic access decisions.

⚠️ ***Exam Trap:*** *Se a decisão depende de atributos dinâmicos como hora, localização, departamento ou tipo de dispositivo, é ABAC.*

• Time-of-Day Restriction (N/A)

An access control constraint that permits or denies access only during specified hours or schedules.

⚠️ ***Exam Trap:*** *Se a questão cita acesso permitido apenas em determinado horário, é time-of-day restriction; pode ser combinada com RBAC ou ABAC.*

• Security-Enhanced Linux (SELinux)

A Linux kernel security module that enforces mandatory access control using labels and policies.

⚠️ ***Exam Trap:*** *SELinux é exemplo clássico de MAC. Se aparecer SELinux, associe a labels/políticas obrigatórias, não a decisões do dono.*

• Data Classification (N/A)

The process of labeling data based on sensitivity (e.g., public, confidential, secret) to determine handling and access requirements.

⚠️ ***Exam Trap:*** *Em MAC, a classificação do dado e a habilitação do usuário determinam o acesso. A frase 'permissions determined by data classification' aponta para MAC.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Discretionary Access Control (DAC) - The Homeowner Decides

🏠 **Real-World Analogy:** You own a private suburban house. You determine entirely at your own discretion who enters your study, swims in your pool, or borrows tools from your shed. You can freely hand a duplicate front-door key to a neighbor without government oversight. Under DAC, the user creating a digital object is its authoritative Owner, possessing total discretion to grant read/write access to any other user on the system.

🔍 **Root Cause & Background:** Engineered during the dawn of personal computing to maximize end-user autonomy and convenience, prioritizing frictionless sharing over strict organizational security governance.

🛡️ **GRC Auditor Perspective:** Auditors flag DAC as high-risk for regulated data stores because any careless resource owner can grant unrestricted access to the 'Everyone' group, causing catastrophic regulatory non-compliance.

⚠️ **How CompTIA Tests This:** Exam trigger: 'access control model where the creator/owner of an object controls permissions and grants privileges at their discretion' = Discretionary Access Control (DAC).

📌 Mandatory Access Control (MAC) - The Military Base with Labels & Clearances

🏠 **Real-World Analogy:** A top-secret military installation. Even if a Colonel drafts a memo on their personal notepad, they are strictly forbidden from showing it to their driver if security classified the document as 'TOP SECRET' and the driver only holds 'CONFIDENTIAL' clearance. Under MAC, neither file creators nor end-users possess the authority to change permissions; access is dictated immutably by central policy matching object security labels to subject clearance levels.

🔍 **Root Cause & Background:** Designed to prevent national security compromises across classified government environments where access determinations cannot be delegated to fallible human discretion.

🛡️ **GRC Auditor Perspective:** Auditing automated label tagging across data stores; verifying security clearance background checks; and inspecting systems implementing formal Bell-LaPadula confidentiality rules (No Read Up, No Write Down).

⚠️ **How CompTIA Tests This:** Exam trigger: 'strictest access control model based on security labels attached to objects and clearance levels assigned to subjects' = Mandatory Access Control (MAC).

📌 Role-Based Access Control (RBAC) - The Professional Role Badge

🏠 **Real-World Analogy:** A modern metropolitan hospital. When hired as a 'Night Shift Nurse', an employee is issued a standard role badge. That badge automatically opens the floor medicine dispensary and grants read access to admitted patient charts. They receive permissions not because their name is 'Paul', but because of their active professional role. If promoted to 'Hospital Administrator', the nursing role is revoked, and the administrative role permissions are assigned.

🔍 **Root Cause & Background:** Managing user-level permissions across large enterprises is administratively unscalable and error-prone. Grouping access rights into organizational roles drastically streamlines onboarding and access provisioning.

🛡️ **GRC Auditor Perspective:** Conducting quarterly User Access Reviews to remediate Privilege Creep resulting from internal department transfers; verifying Segregation of Duties (SoD) policies to prevent conflicting role assignments.

⚠️ **How CompTIA Tests This:** Exam trigger: 'permissions are assigned to roles defined by job duties, and users are granted roles' = Role-Based Access Control (RBAC). Governance trigger: 'mitigates privilege creep during role changes'.

📌 Attribute-Based Access Control (ABAC) - Contextual Dynamic Policy Engine

🏠 **Real-World Analogy:** An AI-powered high-security banking portal. Rather than checking only a job title, it evaluates a matrix of real-time attributes before unlocking: 'Is the subject a certified financial officer (subject attribute)? Yes. Is the target file labeled sensitive financial ledger (resource attribute)? Yes. Is access requested during approved working hours (environmental/time attribute)? Yes. Is the request originating from a managed enterprise laptop physically within corporate headquarters (device/location attribute)? Yes'. If an identical request originates from an unrecognized IP in another country at midnight, access is automatically blocked.

🔍 **Root Cause & Background:** Hybrid cloud models and mobile workforces rendered static role boundaries inadequate, necessitating dynamic, policy-driven Zero Trust evaluations factoring in endpoint posture, geo-location, and risk score.

🛡️ **GRC Auditor Perspective:** Auditing Cloud Conditional Access policies; reviewing attribute policy evaluation logic (XACML standards); and testing automated blocking of logins originating from impossible travel velocities or untrusted networks.

⚠️ **How CompTIA Tests This:** Exam trigger: 'dynamic access decisions evaluated against subject, object, environmental, and contextual attributes (time of day, device compliance, location)' = Attribute-Based Access Control (ABAC).

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Access control model where the object creator retains full discretionary authority to assign permissions	**Discretionary Access Control (DAC)**
Strictest security model granting access strictly based on object classification labels and subject security clearance levels	**Mandatory Access Control (MAC)**
Permissions provisioned to employees strictly according to defined organizational job responsibilities	**Role-Based Access Control (RBAC)**
Dynamic access determinations evaluated against contextual parameters including time, endpoint health, and geolocation	**Attribute-Based Access Control (ABAC)**
Unchecked accumulation of historical user permissions resulting from multiple lateral transfers within an enterprise	**Privilege Creep**
Internal governance control ensuring no single individual maintains authority to execute and conceal high-risk actions	**Segregation of Duties (SoD)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A file server administrator reviews how permissions are assigned to a shared folder. Each folder has a list that specifies which individual users and groups can read, write, or delete files, and the operating system checks that list every time a user opens a file. Which access control mechanism is described?

A) Mandatory access control (MAC)

B) Role-based access control (RBAC)

C) Access control list (ACL)

D) Attribute-based access control (ABAC)

QUESTION 2 · EXAM SCENARIO

A defense agency stores documents labeled Confidential, Secret, and Top Secret. The operating system compares each document's label with the user's clearance and need-to-know before allowing access. Neither the document owner nor the user can change the label or bypass the decision. Which access control model is in use?

A) Mandatory access control (MAC)

B) Discretionary access control (DAC)

C) Role-based access control (RBAC)

D) Attribute-based access control (ABAC)

QUESTION 3 · EXAM SCENARIO

A Linux administrator is hardening a web server. The kernel enforces policy rules that confine the web server process to specific file types, even if the process runs as root. Administrators cannot simply change file ownership to grant broader access; the policy must be modified. Which technology or model is providing this control?

A) Discretionary access control via NTFS permissions to eliminate single points of operational failure

B) Security-Enhanced Linux (SELinux) mandatory access control

C) Role-based access control via sudoers without disrupting production workload availability

D) Attribute-based access control via RADIUS attributes to enforce least privilege and reduce attack surfaces

QUESTION 4 · EXAM SCENARIO

A marketing team stores project files on a Windows server. The user who created a folder can decide which coworkers may access it and can change the NTFS permissions without involving a security administrator. Which access control model does this describe?

A) Mandatory access control (MAC)

B) Role-based access control (RBAC)

C) Attribute-based access control (ABAC)

D) Discretionary access control (DAC)

QUESTION 5 · EXAM SCENARIO

A hospital's electronic health record system assigns permissions to job functions such as physician, nurse, and billing specialist. When an employee moves from billing to nursing, the administrator changes the employee's assignment, and the system automatically grants the nursing permissions and removes billing permissions. Which model is being used?

A) Role-based access control (RBAC)

B) Discretionary access control (DAC)

C) Mandatory access control (MAC)

D) Attribute-based access control (ABAC)

QUESTION 6 · EXAM SCENARIO

A cloud application grants access to a document only when the user's department matches the document's project tag, the user has completed required training, the request comes from a managed device, and the time is within approved hours. The authorization engine evaluates all these conditions together. Which access control model is this?

A) Mandatory access control (MAC) to enforce least privilege and reduce attack surfaces

B) Discretionary access control (DAC) through automated configuration orchestration pipelines

C) Attribute-based access control (ABAC)

D) Role-based access control (RBAC) using standardized security content automation profiles

QUESTION 7 · EXAM SCENARIO

A facility uses badge readers for contractors. A contractor's badge is valid for entry only between 07:00 and 18:00 on weekdays. At 20:00, the badge is denied even though the contractor still has the correct role and clearance. Which access control restriction is being enforced?

A) Mandatory access control (MAC)

B) Discretionary access control (DAC)

C) Role-based access control (RBAC)

D) Time-of-day restriction

QUESTION 8 · EXAM SCENARIO

A network security administrator configures a firewall rule set that permits or denies traffic based on source IP address, destination IP address, and TCP port. The list is processed in order, and the first matching rule determines the action. Which access control concept is this?

A) Mandatory access control (MAC)

B) Access control list (ACL)

C) Discretionary access control (DAC)

D) Role-based access control (RBAC)

QUESTION 9 · EXAM SCENARIO

A financial institution must limit access to a trading system to authorized roles during trading hours and block access at all other times. Which two access control concepts are combined in this requirement?

A) RBAC and time-of-day restriction

B) MAC and DAC to prevent unauthorized configuration drift across nodes

C) ABAC and SELinux across all managed enterprise endpoints

D) ACL and discretionary access while maintaining continuous telemetry and monitoring

QUESTION 10 · EXAM SCENARIO

A security architect must design access for a multinational company. The decision must consider the user's department, project assignment, the resource's classification, the user's geographic location, and whether the device is compliant. Which access control model is most appropriate?

A) Discretionary access control (DAC) to prevent unauthorized configuration drift across nodes

B) Mandatory access control (MAC) across all managed enterprise endpoints

C) Role-based access control (RBAC) while maintaining continuous telemetry and monitoring

D) Attribute-based access control (ABAC)

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Access control list (ACL)
An ACL is a list attached to a resource that specifies which subjects have which permissions. MAC uses security labels and clearances, RBAC uses job roles, and ABAC uses multiple attributes such as department, device, or location.

Question 2: Option A — Mandatory access control (MAC)
MAC enforces access decisions using security labels and formal clearances. DAC lets owners set permissions, RBAC uses job roles, and ABAC evaluates attributes.

Question 3: Option B — Security-Enhanced Linux (SELinux) mandatory access control
SELinux implements MAC using policy and type labels, so processes are confined regardless of traditional owner or root permissions. NTFS is DAC, sudoers is RBAC-like, and RADIUS attributes are not a kernel MAC system.

Question 4: Option D — Discretionary access control (DAC)
DAC allows the resource owner to determine access permissions. MAC uses labels and clearances, RBAC uses roles, and ABAC uses attributes.

Question 5: Option A — Role-based access control (RBAC)
RBAC assigns permissions to roles, and users receive permissions through role membership. DAC is owner-controlled, MAC is label and clearance based, and ABAC evaluates many attributes.

Question 6: Option C — Attribute-based access control (ABAC)
ABAC makes decisions by evaluating attributes of the subject, resource, action, and environment. MAC, DAC, and RBAC do not natively combine all these dynamic conditions in one policy decision.

Question 7: Option D — Time-of-day restriction
A time-of-day restriction limits access based on the current time or schedule. MAC uses labels, DAC uses owner permissions, and RBAC uses roles, none of which alone explain the 20:00 denial.

Question 8: Option B — Access control list (ACL)
A firewall rule set is a form of ACL: a list of permit or deny entries matched against traffic attributes. MAC uses labels, DAC uses owner permissions, and RBAC uses roles.

Question 9: Option A — RBAC and time-of-day restriction
Authorized roles indicate RBAC, while allowing access only during trading hours is a time-of-day restriction. MAC and DAC, ABAC and SELinux, and ACL and DAC do not accurately describe this combined role-and-schedule requirement.

Question 10: Option D — Attribute-based access control (ABAC)
ABAC is designed to evaluate multiple subject, resource, and environmental attributes in a single policy decision. DAC uses owner discretion, MAC uses labels and clearances, and RBAC uses roles, but the scenario requires broader attribute-based conditions.